

5. Security & Compliance Documentation

Authentication / Authorization

- Auth flow: OAuth2 / JWT issued by Auth Service. Token refresh, scopes, and RBAC mapping.

Encryption Standards

- In-transit: TLS 1.2+ with strong ciphers.
- At-rest: AES-256 for DB backups and object storage.

Key Management

- Keys stored in KMS (cloud provider) or Vault; rotation policy: 90 days for symmetric keys, yearly for asymmetric.

Threat Model & Mitigations

- Top threats: injection, auth bypass, data exfiltration.
- Mitigations: input validation, parameterized queries, WAF, least privilege.

Vulnerability Management

- Regular SCA and dependency scans; CVE triage within 48 hours for critical.

Audit & Logging

- Immutable audit logs for sensitive actions; retention policy per compliance.

Compliance Controls

- GDPR: data subject requests, deletion flows, data portability.